

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Assessing Provider Risk Programs and Data Roles

1. Learning Objectives

- By the end of this lecture, you will be able to Identify the key indicators of a mature cloud provider risk management programme and explain what evidence satisfies each indicator.
- By the end of this lecture, you will be able to Explain the legal and operational significance of the data owner, data custodian, data steward, data processor, and data controller roles.
- By the end of this lecture, you will be able to Distinguish between the data custodian and data processor roles and explain when each applies in a cloud context.
- By the end of this lecture, you will be able to Describe the contractual obligations triggered when a cloud provider acts as a data processor under GDPR Article 28.
- By the end of this lecture, you will be able to Apply the shared responsibility model to a cloud risk scenario by mapping each risk category to the responsible party.

2. Introduction: Trust as an Evidence Problem

A global pharmaceutical company's data governance team is reviewing three cloud providers shortlisted for hosting its drug efficacy trial datasets. Each provider has sent a polished capabilities deck listing compliance badges. One has a SOC 2 Type II. Another has an ISO/IEC 27001 certificate. The third offers a vendor attestation letter signed by its own CISO. The team treats these three inputs very differently — and understanding why is the entire point of this lecture.

In cloud security governance, the distinction between a claim and evidence of a claim is everything. Any provider can assert that it takes security seriously. Assessing whether that assertion is supported by documented, independently verified controls requires knowing what to look for and what standard the evidence must meet. This lecture covers both the provider-side assessment — what indicators signal a mature risk programme — and the customer-side accountability question — who is legally responsible for what when data is handled in a cloud environment.

The data role definitions are not just legal vocabulary. They determine accountability when something goes wrong, they define the contract terms that must be in place under privacy regulations, and they appear repeatedly in CCSP scenario questions that test whether candidates understand who bears responsibility for which aspect of data protection.

3. Core Concepts Explained

3.1 Assessing a Cloud Provider's Risk Programme

Definition: Provider risk programme assessment is the structured evaluation of a cloud service provider's documented risk management practices, using objective evidence rather than self-assessed claims.

Business relevance: Under the shared responsibility model, the customer retains accountability for meeting its regulatory obligations regardless of which controls the provider is responsible for. If the provider's controls fail, the customer still faces regulatory scrutiny. Due diligence on the provider's risk programme is therefore not optional — it is a governance requirement.

The three primary evidence categories a mature provider will be able to produce:

First, a current risk register. A risk register is a working document — not a historical snapshot. A provider with a genuine risk programme can show a risk register that has been reviewed and updated recently, with identified threats and vulnerabilities, current likelihood and impact ratings, and documented treatment decisions. A risk register last updated eighteen months ago is not evidence of an active programme. It is evidence that one existed at some point.

Second, alignment to recognised frameworks. ISO 31000 provides the process. ISO/IEC 27001 provides the control framework for the ISMS. NIST SP 800-37 provides the RMF. The CSA Cloud Controls Matrix provides cloud-specific control categories. A provider that can map its controls to one or more of these frameworks gives the customer an objective baseline to compare against — rather than a self-defined standard with no external reference point.

Third, third-party audit reports. A SOC 2 Type II, an ISO/IEC 27001 certification, or a FedRAMP authorisation are not self-assessments. They involve independent qualified professionals examining the provider's controls and producing written findings. These reports are the most credible evidence available and should be the primary instrument in any provider assessment.

Additional operational indicators: a formal vulnerability disclosure programme (does the provider have a defined channel for receiving and acting on reported vulnerabilities?), documented patch management timelines (how quickly are critical patches applied?), and evidence of regular penetration testing by independent parties.

Case Study: In 2019, Capital One disclosed a breach affecting over 100 million customer records stored on AWS. AWS held a current SOC 2 Type II report confirming the operating effectiveness of its infrastructure controls. The breach did not originate from an AWS control failure — it originated from a server-side request forgery (SSRF) misconfiguration in Capital One's own application, which allowed a former AWS employee to extract data from a misconfigured WAF. The lesson is not that SOC 2 reports are unreliable — it is that they cover the provider's scope. The

customer's application configuration remains the customer's responsibility. Provider assurance and customer-side control are not substitutes for each other.

3.2 Data Owner

Definition: The data owner is the individual or organisational entity with ultimate accountability for a dataset — responsible for its classification, access authorisation, retention, and disposal.

Business relevance: Data ownership does not transfer to the cloud provider when data is migrated to the cloud. The business unit that generated or depends on the data retains ownership. This is critical for compliance: if the data owner cannot account for where data is, how it is classified, and who has access, the organisation cannot satisfy regulatory obligations regardless of how technically secure the cloud infrastructure is.

Practitioner angle: In practice, data ownership is often ambiguous. Multiple departments may contribute to or consume the same dataset. Establishing clear ownership — typically at the level of a named senior manager or executive sponsor — is a prerequisite for effective data governance. The data owner approves classification levels, defines retention schedules, and authorises destruction decisions.

Real-world example: At a major retail bank, the Head of Personal Banking owns the customer demographics dataset. She approves who can access it, sets the data classification as Confidential, and authorises the annual retention review. When the bank migrates this dataset to cloud storage, her ownership and accountability do not change — only the physical location of the data changes.

3.3 Data Custodian

Definition: The data custodian is responsible for the physical and logical safekeeping of data on behalf of the owner — managing storage infrastructure, implementing backups, enforcing access controls, and executing the owner's directives.

Business relevance: Cloud service providers frequently act as data custodians. They store and protect data within their infrastructure under the customer's direction. The custodian's accountability is operational, not strategic — they implement, but do not set, data governance policy.

Practitioner angle: The custodian's duties are defined by the owner. This means the quality of the custodial relationship depends on how clearly the owner has specified requirements — through contracts, policies, and SLAs. A custodian that has not been given clear instructions about retention periods, encryption standards, or access controls cannot be held responsible for failing to meet requirements that were never communicated.

Key distinction: A custodian stores and maintains data; they do not determine the purpose or means of its use. This separates custodians from processors, which is important under GDPR.

3.4 Data Steward

Definition: The data steward is an operational role within the organisation responsible for day-to-day data governance: enforcing classification policies, maintaining metadata, ensuring data quality, and acting as the working link between the data owner's decisions and the people who handle data in practice.

Business relevance: Data stewards make abstract governance policies operational. They answer questions from business users about data classification, flag anomalies in data quality, maintain the data catalogue, and escalate issues to the data owner.

Practitioner angle: In cloud environments, data stewards often manage the interaction between the organisation's data governance framework and the provider's controls — ensuring that the owner's classification decisions are reflected in the tags, access policies, and retention rules applied to cloud storage objects.

3.5 Data Controller (GDPR)

Definition: Under GDPR and similar privacy frameworks, the data controller determines the purpose for which personal data is collected and the means by which it is processed. The controller bears the primary legal obligation to data subjects.

Business relevance: If your organisation collects customer data, defines what it is used for, and decides how it is stored and accessed, your organisation is the controller. The controller must identify a lawful basis for processing, publish a privacy notice, respond to data subject requests, and notify regulators of breaches within defined timeframes (72 hours under GDPR).

Practitioner angle: A key CCSP concept: the controller cannot use a processor without a written data processing agreement (DPA) that meets GDPR Article 28 requirements. Absent the DPA, the controller is not in compliance — regardless of how technically secure the processing is. The DPA is not optional; it is a legal requirement.

3.6 Data Processor (GDPR)

Definition: The data processor handles personal data on behalf of a controller, following the controller's instructions. Processors carry their own GDPR obligations, including implementing appropriate security measures and notifying the controller of breaches.

Business relevance: A cloud analytics platform that processes your customers' personal data on your instructions is a data processor. So is a cloud email marketing service, a cloud HR system, and a cloud payroll provider. Each of these relationships requires a GDPR-compliant DPA.

Practitioner angle: The distinction between custodian and processor is frequently tested on the CCSP exam. A custodian stores and maintains data passively. A processor actively handles personal data in ways specified by a controller as part of a defined service. A cloud storage provider is a custodian. A cloud analytics service that ingests, transforms, and analyses that data is a processor.

Real-world example: A UK insurance company (controller) uses a cloud-based underwriting analytics platform (processor) that applies machine learning models to customer claims history. The DPA specifies: the categories of personal data processed, the purpose (underwriting risk assessment), the technical and organisational security measures required, the data retention period, and the sub-processor arrangements the analytics provider may use. Without this DPA, the insurer is not GDPR-compliant regardless of how good the analytics platform's encryption is.

Think of the controller/processor distinction as: a restaurant relationship. The restaurant (controller) decides what dishes to prepare, selects the ingredients, and sets the menu — it determines the purpose and means of food preparation. The kitchen supplier (processor) delivers and stores the ingredients under the restaurant's specification. The supplier does not decide what gets cooked. But if the supplier's cold storage fails and the ingredients spoil, the supplier bears responsibility for that operational failure, and must tell the restaurant (notify the controller) so the restaurant can decide what to tell its customers.

4. Data Roles Comparison

Role	Primary Accountability	Determines Purpose?	Handles Data Operationally?	Cloud Context
Data Owner	Ultimate accountability for classification, access, retention, disposal	Yes (for the dataset)	No (delegates to steward/custodian)	Business unit head; accountability survives cloud migration
Data Custodian	Physical and logical safekeeping of data	No — follows owner's directives	Yes — storage, backup, access control	Cloud provider frequently acts as custodian
Data Steward	Day-to-day data governance and quality	No — implements owner's decisions	Yes — classification enforcement, metadata, data quality	Bridge between policy and cloud operations
Data Controller (GDPR)	Determines purpose and means of processing personal data	Yes — legally responsible to data subjects	May or may not handle directly	The customer organisation in most cloud scenarios
Data Processor (GDPR)	Processes personal data on behalf of controller	No — follows controller's instructions	Yes — the primary processing activity	Cloud SaaS/analytics vendor handling personal data

5. Provider Assessment Indicators — Maturity Matrix

Indicator	What a Mature Programme Shows	Red Flag
Risk Register	Updated within 3–6 months; includes likelihood/impact ratings and treatment decisions	Last updated 12+ months ago; no treatment decisions documented
Framework Alignment	Documented mapping to ISO 31000, ISO 27001, NIST RMF, or CSA CCM	No framework reference; self-defined standard only
Third-Party Audit Reports	Current SOC 2 Type II, ISO 27001 cert, or FedRAMP authorisation	Self-attestation letter; expired or Type I only
Vulnerability Management	Defined VDP; critical patch SLA (e.g., 30 days); independent pen test results	No VDP; no patch timelines; no external testing
Subservice Organisation Coverage	Inclusive or carve-out SOC reports for all material subservice organisations	Primary report only; subservice controls unexamined

6. Exam Focus

- Data owner retains accountability when data moves to the cloud — ownership is not transferred to the provider.
- Data custodian = stores and maintains data on behalf of the owner. Cloud providers frequently serve this role.
- Data processor = GDPR term for an entity that handles personal data on behalf of a controller. Requires a DPA under Article 28.
- The custodian/processor distinction: custodians store passively; processors actively handle personal data per controller instructions.
- Data controller = determines purpose and means of processing. Primary legal accountability under GDPR.
- GDPR Article 28 DPA is not optional — it is a legal requirement for any controller-processor relationship.
- Common distractor: selecting 'data custodian' for a GDPR scenario involving active processing of personal data. The correct answer is 'data processor.'
- Common distractor: choosing a vendor's self-attestation as sufficient assurance. Third-party audit reports (SOC 2 Type II, ISO 27001 cert) are required for credible assurance.
- Risk register currency matters: an outdated risk register is evidence of a dormant programme, not a working one.

7. Key Terms Glossary

Data Owner: The individual or entity with ultimate accountability for a dataset's classification, access, retention, and disposal.

Data Custodian: The party responsible for the physical and logical safekeeping of data on behalf of the owner; cloud providers frequently serve this role.

Data Steward: An operational role responsible for day-to-day data governance, classification enforcement, metadata management, and data quality.

Data Controller: Under GDPR: the entity that determines the purpose and means of processing personal data; bears primary legal obligation to data subjects.

Data Processor: Under GDPR: an entity that handles personal data on behalf of and under the instructions of a controller.

Data Processing Agreement (DPA): A legally required contract between a controller and processor under GDPR Article 28, specifying the terms of personal data processing.

Risk Register: A living document recording identified risks, their likelihood and impact ratings, and treatment decisions; currency is a key maturity indicator.

Third-Party Audit Report: An independently produced assessment of a provider's controls — SOC 2 Type II, ISO 27001 cert, FedRAMP ATO — as distinct from self-attestation.

Vulnerability Disclosure Programme (VDP): A formal channel through which external parties can report security vulnerabilities to a provider for triage and remediation.

Shared Responsibility Model: The cloud operating model that divides security and compliance accountabilities between the cloud provider and the customer based on service type.

Framework Alignment: A provider's documented mapping of its controls to recognised standards such as ISO 27001, NIST RMF, or the CSA Cloud Controls Matrix.

Subservice Organisation: A third party whose services form part of a service organisation's system and whose controls may require separate audit coverage.

8. Quick Revision Checklist

- ☐ I can list the three primary indicators of a mature provider risk programme.
- ☐ I know that data ownership does not transfer to a cloud provider when data is migrated.
- ☐ I can distinguish between the data custodian (stores on owner's behalf) and the data processor (handles personal data per controller instructions).
- ☐ I can define the data controller role and explain its primary GDPR obligation.
- ☐ I know that a GDPR-compliant Data Processing Agreement is legally required for any controller-processor relationship.
- ☐ I can identify which data role a cloud SaaS provider most commonly occupies under GDPR.

- ☐ I understand that a self-attestation letter does not provide equivalent assurance to a SOC 2 Type II report.
- ☐ I can explain why a stale risk register is a governance red flag.
- ☐ I can apply the shared responsibility model to map who is accountable for which risk.
- ☐ I know the difference between data steward (operational governance) and data owner (strategic accountability).

9. Practice Questions (10 MCQs)

Question 1 (Scenario-Based Question)

Scenario: A London-based fintech company uses a cloud-based payments analytics platform to analyse transaction data for its retail banking customers. The fintech company collects the transaction data, defines the analytical models to be applied, and controls which customers' data is processed. The analytics platform executes the models and returns results. Under GDPR, which roles do the fintech company and the analytics platform occupy respectively?

- A) Fintech = data owner; analytics platform = data custodian — Incorrect. Data owner and custodian are data governance roles, not GDPR legal roles. The GDPR framework uses controller and processor, and the scenario describes a controller-processor relationship.
- B) Fintech = data processor; analytics platform = data controller — Incorrect. The fintech company determines the purpose (customer analytics) and the means (which models to apply, whose data to process). That is the controller role. The platform executes per the fintech's instructions — that is the processor role.
- C) Fintech = data controller; analytics platform = data processor — Correct.** The fintech company determines the purpose and means of processing (controller). The analytics platform handles personal data on behalf of and under the instructions of the fintech (processor). A GDPR Article 28 Data Processing Agreement is required.
- D) Fintech = data steward; analytics platform = data owner — Incorrect. These are internal data governance roles, not GDPR legal classifications applicable to a service relationship between two separate organisations.

Question 2 (Scenario-Based Question)

Scenario: A healthcare insurer is conducting due diligence on a cloud-based claims processing platform before migrating sensitive policyholder data. The platform vendor provides three documents: (1) a self-attestation letter signed by its CISO, (2) a SOC 2 Type I report from eighteen months ago, and (3) an ISO/IEC 27001 certificate valid until next year. Which of these provides the strongest credible assurance about the current operating effectiveness of the vendor's security controls?

A) The self-attestation letter, because it is signed by the most senior security officer. — Incorrect. A self-attestation is the weakest form of assurance regardless of who signs it. It represents the vendor's own opinion of its security posture, not an independent evaluation.

B) The SOC 2 Type I report, because it was produced by an independent auditor. — Incorrect. While independent, a SOC 2 Type I assesses design only at a specific point in time — and eighteen months ago at that. It does not confirm that controls operated effectively and provides no assurance about the current state.

C) The ISO/IEC 27001 certificate, because it was independently issued and remains current. — Correct. An ISO/IEC 27001 certificate is issued by an accredited third-party certification body and requires annual surveillance audits to remain valid. A certificate valid until next year means a surveillance audit has recently confirmed the ISMS is functioning. This is the strongest current assurance available from the three documents provided.

D) All three documents together provide equivalent assurance to a SOC 2 Type II. — Incorrect. Three weaker assurance instruments do not combine to equal a SOC 2 Type II report. The Type II's value lies in its independent examination of control operating effectiveness over a defined period — which none of the three documents individually or collectively provides.

Question 3 (Scenario-Based Question)

Scenario: An organisation has migrated its customer records to a cloud object storage service. The Head of Customer Operations retains accountability for which customers have access to their own records, sets the data classification as 'Confidential - Personal', and determines that records must be retained for seven years. The cloud provider manages the physical storage, replication, and backup of the objects. Which data governance roles do the Head of Customer Operations and the cloud provider occupy respectively?

A) Head of Customer Operations = data processor; cloud provider = data controller — Incorrect. The Head of Customer Operations sets classification and retention — these are owner-level decisions, not processor functions. The cloud provider stores data per the customer's direction, which is custodial, not controller.

B) Head of Customer Operations = data owner; cloud provider = data custodian — Correct. The Head of Customer Operations retains ultimate accountability for classification, access, and retention — the defining characteristics of data ownership. The cloud provider manages physical and logical safekeeping per the owner's direction — the defining characteristics of data custodianship.

C) Head of Customer Operations = data steward; cloud provider = data processor — Incorrect. A data steward manages day-to-day governance but does not hold strategic accountability. The Head of Customer Operations sets policy, which is ownership. The cloud provider stores — not actively processes personal data per GDPR — making custodian the more accurate role here.

D) Head of Customer Operations = data controller; cloud provider = data processor — Partially plausible but less precise in this context. The scenario uses data governance role terminology (classification, retention, custodianship) rather than GDPR processing terminology. The more accurate answer within the data governance framework described is data owner and data custodian.

Question 4 (Knowledge Question)

Which of the following is the legally required document under GDPR Article 28 that must exist between a data controller and a data processor before the processor handles personal data?

A) A Service Level Agreement (SLA) — Incorrect. An SLA governs service performance and availability, not the lawful basis and conditions for processing personal data. While an SLA is important, it does not satisfy Article 28 requirements.

B) A Data Processing Agreement (DPA) — Correct. GDPR Article 28 requires a binding written contract — the Data Processing Agreement — between any controller and processor. It must specify the nature, purpose, and duration of processing; the types of personal data; the data subjects' categories; and the processor's obligations including security measures and sub-processor arrangements.

C) A Non-Disclosure Agreement (NDA) — Incorrect. An NDA is a confidentiality instrument. It does not address the lawful processing terms, security obligations, breach notification requirements, or sub-processor controls required by Article 28.

D) A SOC 2 Type II audit report — Incorrect. A SOC 2 report is an assurance instrument demonstrating control effectiveness. It is not a contract between a controller and processor and does not constitute compliance with Article 28.

Question 5 (Knowledge Question)

What is the key difference between the data custodian role and the data processor role?

A) The custodian owns the data; the processor merely stores it. — Incorrect. Neither custodians nor processors own the data. Ownership rests with the data owner. Custodians store and maintain; processors actively handle personal data per controller instructions.

B) The custodian stores and maintains data passively on behalf of the owner; the processor actively handles personal data according to a controller's instructions. — Correct. This is the critical distinction. A cloud storage provider is typically a custodian — it stores your data without actively processing it for a defined purpose. A cloud analytics or SaaS platform that ingests, transforms, and produces outputs from personal data is a processor under GDPR, with attendant legal obligations including the requirement for a DPA.

C) The custodian is always an internal employee; the processor is always an external vendor. — Incorrect. Both roles can be filled by internal or external parties. The role definition depends on the function performed, not on whether the party is inside or outside the organisation.

D) The custodian determines data retention; the processor determines data classification. — Incorrect. Neither role determines retention or classification — those decisions belong to the data owner. Custodians implement the owner's retention decisions. Processors follow the controller's processing instructions.

Question 6 (Knowledge Question)

An organisation's due diligence team requests a cloud provider's risk register as part of a vendor assessment. The provider shares a document dated fourteen months ago. What conclusion should the team draw?

A) The risk register confirms that the provider has an active risk management programme. — Incorrect. A fourteen-month-old risk register does not confirm an active programme — it confirms a programme existed over a year ago. Currency is a primary indicator of whether risk management is ongoing or dormant.

B) The stale risk register suggests the provider's risk management programme may not be actively maintained, and a more current document or explanation should be requested. — Correct. A well-maintained risk register is updated at regular intervals — typically quarterly or in response to significant changes. A document that is fourteen months old is outside any reasonable update cycle and raises doubt about whether the programme is functioning as described.

C) The age of the document is irrelevant; what matters is whether the register identifies risks at all. — Incorrect. A risk register that was accurate fourteen months ago may not reflect the current threat landscape, new cloud services deployed, recent regulatory changes, or emerging vulnerabilities. Currency is essential to its usefulness.

D) The risk register should be rejected and the provider should be disqualified from the assessment. — Incorrect. Requesting an updated document or an explanation is the appropriate first step. Outright disqualification based on one stale document, without seeking clarification, is disproportionate and may exclude providers who have current documentation but filed the wrong version.

Question 7 (Knowledge Question)

Which party in the GDPR framework bears the primary legal obligation to data subjects — including the duty to establish a lawful basis for processing, respond to subject access requests, and notify regulators of breaches within 72 hours?

A) Data processor — Incorrect. While processors have their own GDPR obligations — security measures, breach notification to the controller, sub-processor controls — primary legal accountability to data subjects rests with the controller.

B) Data custodian — Incorrect. The data custodian is a data governance role without direct GDPR legal status. GDPR obligations fall on controllers and processors.

C) Data controller — Correct. The data controller determines the purpose and means of processing and bears primary legal accountability under GDPR. This includes identifying a lawful basis, providing privacy notices, responding to data subject rights requests, and notifying the supervisory authority within 72 hours of becoming aware of a breach.

D) Data steward — Incorrect. The data steward is an operational governance role within an organisation. It is not a legal GDPR classification and does not bear regulatory accountability to data subjects.

Question 8 (Knowledge Question)

A cloud provider's SOC 2 Type II report uses the carve-out method for a colocation data centre that provides physical infrastructure for part of the provider's platform. What action must the cloud customer take to complete their assurance picture?

A) Accept the provider's primary SOC 2 report as sufficient; subservice controls are covered by implication. — Incorrect. The carve-out method explicitly excludes subservice organisation controls from the auditor's scope. The customer cannot assume those controls have been examined.

B) Request a separate SOC 2 report from the colocation provider covering the relevant control period. — Correct. When the carve-out method is used, the auditor does not examine the subservice organisation's controls. To obtain complete assurance, the customer must obtain the subservice organisation's own SOC 2 report and review it alongside the primary provider's report.

C) Request that the primary provider switch to the inclusive method in the next audit cycle, and defer reliance until then. — Partially correct as a future action, but does not address the immediate need. In the current cycle, the customer should obtain the subservice organisation's report now rather than waiting.

D) Commission an independent penetration test of the colocation facility to compensate for the gap. — Incorrect. A penetration test examines technical exploitability, not the full range of controls covered by a SOC 2 engagement. It does not produce the equivalent assurance.

Question 9 (Knowledge Question)

Which of the following best describes the function of a data steward in a cloud data governance programme?

- A) Setting the organisation's data classification policy and approving access to sensitive datasets. — Incorrect. Setting classification policy and approving access are data owner responsibilities. The steward operationalises the owner's decisions.
- B) Physically storing and replicating data on behalf of the data owner. — Incorrect. Physical storage is the data custodian's function. The steward's role is operational governance, not infrastructure management.
- C) Enforcing classification policies, maintaining data quality and metadata, and acting as the operational link between the data owner and data handlers.** — Correct. The data steward bridges strategy (the data owner's decisions) and operations (the people and systems that handle data day-to-day). Stewards enforce policies, manage the data catalogue, and escalate governance issues.
- D) Negotiating the data processing agreement with cloud service providers on behalf of the organisation. — Incorrect. Negotiating contracts is a legal and procurement function. The data steward is an operational governance role, not a legal or commercial one.

Question 10 (Knowledge Question)

Which scenario most accurately describes the application of the shared responsibility model in cloud risk assessment?

- A) The cloud provider is responsible for all security controls; the customer is responsible only for defining business requirements. — Incorrect. This describes a managed security service model, not the shared responsibility model. In any cloud deployment, customers retain responsibility for their own data, identity management, and application-layer controls.
- B) The customer retains full responsibility for all security controls regardless of deployment model. — Incorrect. In the shared responsibility model, certain controls — physical security, hypervisor integrity, and underlying infrastructure — are the provider's responsibility. The split depends on the service model (IaaS, PaaS, SaaS).
- C) Responsibility is divided between provider and customer based on service model; provider-side controls are evidenced through audit reports, while customer-side controls are the customer's own accountability.** — Correct. This accurately describes the shared responsibility model. The provider's scope is validated through SOC 2 reports, certifications, and audit artefacts. The customer's scope — data classification, identity management, application configuration, workload security — remains the customer's independent accountability.
- D) Risk transfers entirely to the cloud provider once a service level agreement is signed. — Incorrect. An SLA allocates certain performance-related financial obligations but does not

transfer security accountability. The customer remains responsible for its own regulatory compliance and for controls within its scope under the shared responsibility model.